

Informe de Auditoría de Seguridad y Arquitectura

Fecha de Entrega: 31/08/2026

Auditor: Guido Ygounet

Proyecto Auditado: [fork:DDSIA_Final_Integrador-Jose](#) - [Repositorio Original](#)

1. Vulnerabilidades Encontradas (OWASP Top 10 & Riesgos de Sistemas IA)

Basado en la evidencia de los tests de seguridad y arquitectura del código fuente, el sistema presenta una postura defensiva sólida. A continuación, se detallan los riesgos mitigados de forma efectiva y las observaciones correspondientes:

1.1. OWASP Top 10 (Web & API)

- **A01:2021 - Broken Access Control:** El sistema cuenta con controles estrictos. La API valida scopes específicos en los JWT (ej. `ask:read` para analistas y `admin:ingest` para administradores). Además, el tráfico no autenticado también está sujeto a limitación de tasa (rate limiting) para prevenir escaneos y ataques de fuerza bruta.
- **A03:2021 - Injection:** Los ataques de inyección (XSS) están fuertemente mitigados en la interfaz web. El frontend evita explícitamente funciones inseguras como `innerHTML`, `document.write` y `eval`. La aplicación emplea una estricta política CSP (`Content-Security-Policy`) que bloquea la ejecución de scripts en línea (`<script>`, `onclick`) y restringe el origen de los recursos.
- **A05:2021 - Security Misconfiguration:** Los contenedores están fortificados de manera excepcional. Operan con privilegios reducidos (`no-new-privileges:true`), eliminan todas las capacidades por defecto (`cap_drop: [ALL]`), utilizan un sistema de archivos de solo lectura (`read_only: true`), y aplican límites estrictos de CPU y memoria. Asimismo, la documentación de Swagger UI está deshabilitada en el entorno de producción.

1.2. Riesgos Específicos de IA (OWASP Top 10 for LLMs)

- **LLM01: Prompt Injection:** Existe una fuerte capa de validación para prevenir inyecciones. Se interceptan patrones de evasión (ej. "ignora todas las instrucciones") tanto en las preguntas de los usuarios como dentro de los propios documentos ingeridos en el corpus.
- **LLM06: Sensitive Information Disclosure (Data Leakage):** El sistema implementa un filtro de protección de salida que bloquea respuestas que intenten fugar el "system prompt" de la IA y detecta información de identificación personal (PII) como correos electrónicos o números CUIT en las interacciones.

2. Calidad de las Mitigaciones Implementadas

- **Qué está bien implementado:**
 - **Protección de Credenciales:** El frontend almacena los tokens JWT exclusivamente en memoria y prohíbe su guardado en `localStorage` o `cookies`, eliminando el riesgo de robo persistente vía XSS.

- **Control de Presupuesto:** Existen barreras precisas contra los ataques de "Denial of Wallet", incluyendo un límite de peticiones por minuto mediante un `TokenBucketLimiter` por IP/Usuario, y un presupuesto de consumo de tokens estricto (`TokenBudget`).
 - **Qué falta:**
 - **Centralización del Estado:** La gestión del estado de los limitadores de tasa y presupuestos de tokens parece residir en la memoria de la aplicación (`app.state`). Esto podría representar un desafío de inconsistencia si la arquitectura requiere escalar a múltiples réplicas (requeriría Redis u otro almacenamiento distribuido).
 - **Qué sobra:**
 - **Mantenimiento de Expresiones Regulares:** Las defensas de alcance (Scope Guard) y validación de entrada dependen en gran medida del uso de "pattern matching" y reglas fijas para bloquear inyecciones, peticiones de código o variantes de palabras clave. Esta lista de reglas crecerá exponencialmente, volviéndose compleja y frágil de mantener con el tiempo.
-

3. Evaluación de las Decisiones de Arquitectura

- **Rechazo Temprano (Early Rejection):** La arquitectura decide validar el alcance de las consultas (ej. detectar CVEs no permitidos, solicitudes de código puro o componentes fuera de contexto) antes de invocar al modelo LLM. Esto optimiza drásticamente los costos operativos al evitar inferencias inútiles.
 - **Estrategia de Indexación (Chunking):** La división de los documentos del corpus para RAG (Retrieval-Augmented Generation) demuestra un diseño meticuloso. Separa los documentos respetando los encabezados Markdown, limpia el ruido del marcado visual, y descarta deliberadamente secciones de bibliografía para no contaminar el cálculo de "embeddings".
 - **Reconciliación de Estado del Índice:** La arquitectura garantiza que al re-indexar o borrar documentos envenenados, los fragmentos (chunks) huérfanos se eliminen limpiamente de la base de datos vectorial para no generar citas falsas.
-

4. Trade-offs Involucrados

- **Seguridad vs. Latencia/Complejidad:** La implementación de una capa de validación de salida (`Output Guard`) añade un peso considerable al ciclo de vida de la petición. El sistema calcula la similitud de coseno entre el contexto y la respuesta, descarta códigos inventados, y verifica URLs generadas para evitar alucinaciones perjudiciales. Esto prioriza la precisión y seguridad de la información, pero incrementa notablemente la latencia percibida por el usuario.
 - **Seguridad Estricta vs. Experiencia de Usuario (UX):** Los filtros para garantizar que el modelo no exceda el contexto o la nomenclatura específica pueden llegar a rechazar consultas legítimas si los patrones de bloqueo no están calibrados de manera constante.
-

5. Herramientas de Análisis de Seguridad Utilizadas

(Espacios reservados para incorporar los resultados de su entorno de auditoría local)

5.1. SonarQube (Calidad de Código y SAST)

Comando utilizado:

Cuenta gratuita en sonarcloud.io. Resumen de analysis de auditoria.

Captura de pantalla:

Bloodclot24 / DDSIA_Final_Integrador-Jose / Summary

Summary

main

Public

5.9K Lines of Code

Last analysis 2 days ago

2 analysis warnings

6b8e078f

View on GitHub

new code has fewer than 20 lines. [Learn more how to adjust this setting.](#)

Quality gate: [Sonar way](#)

Not computed

The next analysis will update the quality gate status.

Security

17 Open issues

E

Reliability

2 Open issues

C

Maintainability

16 Open issues

A

Accepted Issues

0

Valid issues that were not fixed

Coverage

A few extra steps are needed for SonarQube Cloud to analyze your code coverage.
[Set up coverage analysis](#)

Duplications

1.0%

No conditions set on 8.3K Lines

Security Hotspots Deprecated

0

© 2018-2026 SonarSource Sàrl. All rights reserved.

Terms Pricing Privacy Cookie Policy Security Community Documentation Contact us Status About

Bloodclot24 / DDSIA_Final_Integrador-Jose / Issues

Issues

main

2 analysis warnings

Filters

Software quality

Security17

Reliability2

Maintainability16

Severity

Blocker5

High17

Medium13

Low0

Info0

Code attribute

Status

Security Category

Creation Date

Language

Select issues for bulk actions

Change

35 issues1d 6h effortSort byPriority

config/users.json

Make sure this bcrypt password hash gets revoked, changed, and removed from the code.

Responsibility

SecurityBlocker

cwe secret

Open

Not assigned

L330min effort6 days ago

Make sure this bcrypt password hash gets revoked, changed, and removed from the code.

Responsibility

SecurityBlocker

cwe secret

Open

Not assigned

L930min effort6 days ago

.github/workflows/ci.yml

Use full commit SHA hash for this dependency.

Responsibility

SecurityHigh

cwe former-hotspot

Open

Not assigned

L8730min effort8 days ago

Use full commit SHA hash for this dependency.

Responsibility

SecurityHigh

cwe former-hotspot

Open

Not assigned

L10230min effort8 days ago

3 / 12

Bloodclot24 / DDSIA_Final_Integrador-Jose / Issues

Issues

main

2 analysis warnings

Filters

Software quality

Security17

Reliability2

Maintainability16

Severity

Blocker5

High17

Medium13

Low0

Info0

Code attribute

Status

Security Category

Creation Date

Language

scripts/fetch_corpus.py

LLMs running this code with faulty CLI arguments can escape file system restrictions. Refactor this code to validate the constructed path before accessing the file system.

Intentionality

SecurityHigh

cwe

Open

Not assigned

L43 · 30min effort · 8 days ago

.github/workflows/ci.yml

Using dependencies without locking resolved versions is security-sensitive.

Intentionality

SecurityMedium

No tags

Open

Not assigned

L31 · 1h effort · 8 days ago

Omitting "--only-binary :all:" can lead to the execution of setup scripts. Make sure it is safe here.

Responsibility

SecurityMedium

cwe

Open

Not assigned

L32 · 1h effort · 8 days ago

Using dependencies without locking resolved versions is security-sensitive.

Intentionality

SecurityMedium

No tags

Open

Not assigned

L32 · 1h effort · 8 days ago

Using dependencies without locking resolved versions is security-sensitive.

Intentionality

SecurityMedium

No tags

Open

Not assigned

Bloodclot24 / DDSIA_Final_Integrador-Jose / Issues

Issues

main

2 analysis warnings

Filters

Software quality

Security17

Reliability2

Maintainability16

Severity

Blocker5

High17

Medium13

Low0

Info0

Code attribute

Status

Security Category

Creation Date

Language

Omitting "--only-binary :all:" can lead to the execution of setup scripts. Make sure it is safe here.

Responsibility

SecurityMedium

cwe

Open

Not assigned

L57 · 1h effort · 8 days ago

Using dependencies without locking resolved versions is security-sensitive.

Intentionality

SecurityMedium

No tags

Open

Not assigned

L57 · 1h effort · 8 days ago

Omitting "--only-binary :all:" can lead to the execution of setup scripts. Make sure it is safe here.

Responsibility

SecurityMedium

cwe

Open

Not assigned

L73 · 1h effort · 8 days ago

Dockerfile

Omitting "--only-binary :all:" can lead to the execution of setup scripts. Make sure it is safe here.

Responsibility

SecurityMedium

cwe

Open

Not assigned

L18 · 1h effort · 8 days ago

Using dependencies without locking resolved versions is security-sensitive.

Intentionality

SecurityMedium

No tags

Open

Not assigned

L18 · 1h effort · 8 days ago

4 / 12

Bloodclot24 / DDSIA_Final_Integrador-Jose / Issues

Issues

main

2

2 analysis warnings

Filters

Software quality

Security17

Reliability2

Maintainability16

Severity

Blocker5

High17

Medium13

Low0

Info0

Code attribute

Status

Security Category

Creation Date

Language

"password" detected here, review this potentially hard-coded credential.

Responsibility

Security

Medium

Open

Not assigned

L330

30min effort

6 days ago

pyproject.toml

Dependency versions are not predictable if the lock file (uv.lock, poetry.lock, pdm.lock or pylock.toml) is missing.

Intentionality

Security

Medium

Open

Not assigned

5min effort

4 days ago

app/guardrails/instruction_patterns.py

Remove or rework this redundant alternative.

Intentionality

Reliability

Medium

Open

Not assigned

L52

5min effort

4 days ago

app/rag/chunking.py

Simplify this regular expression to reduce its runtime, as it has super-linear performance due to backtracking.

Intentionality

Reliability

Medium

Open

Not assigned

L11

20min effort

8 days ago

evals/eval_fundamentacion.py

Refactor this method to not always return the same value.

Intentionality

Bloodclot24 / DDSIA_Final_Integrador-Jose / Issues

Issues

main

2

2 analysis warnings

Filters

Software quality

Security17

Reliability2

Maintainability16

Severity

Blocker5

High17

Medium13

Low0

Info0

Code attribute

Status

Security Category

Creation Date

Language

Refactor this method to not always return the same value.

Intentionality

Maintainability

Blocker

Open

Not assigned

L186

2min effort

6 days ago

evals/jailbreak_roleplay.py

Refactor this method to not always return the same value.

Intentionality

Maintainability

Blocker

Open

Not assigned

L182

2min effort

6 days ago

evals/preguntas_trampa.py

Refactor this method to not always return the same value.

Intentionality

Maintainability

Blocker

Open

Not assigned

L447

2min effort

6 days ago

app/web/assets/app.js

Prefer '.dataset' over 'removeAttribute(...)'.

Consistency

Maintainability

High

Open

Not assigned

L31

5min effort

6 days ago

Prefer '.dataset' over 'setAttribute(...)'.

Consistency

Maintainability

High

Open

Not assigned

5 / 12

Bloodclot24 / DDSIA_Final_Integrador-Jose / Issues

Issues

main

2

2 analysis warnings

Filters

Software quality

Security17

Reliability2

Maintainability16

Severity

Blocker5

High17

Medium13

Low0

Info0

Code attribute

Status

Security Category

Creation Date

Language

□

Prefer ``.dataset`` over ``.setAttribute(...)``.

Consistency

Maintainability

High

Open

Not assigned

L33

5min effort

6 days ago

app/web/assets/theme.js

□

Unexpected var, use let or const instead.

Intentionality

Maintainability

High

Open

Not assigned

L11

5min effort

6 days ago

□

Unexpected var, use let or const instead.

Intentionality

Maintainability

High

Open

Not assigned

L14

5min effort

6 days ago

□

Prefer ``.dataset`` over ``.setAttribute(...)``.

Consistency

Maintainability

High

Open

Not assigned

L17

5min effort

6 days ago

evals/eval_fundamentacion.py

□

Define a constant instead of duplicating this literal "OWASP API Security Top 10:2023" 3 times.

Adaptability

Maintainability

High

Open

Not assigned

L35

6min effort

6 days ago

Bloodclot24 / DDSIA_Final_Integrador-Jose / Issues

Issues

main

2

2 analysis warnings

Filters

Software quality

Security17

Reliability2

Maintainability16

Severity

Blocker5

High17

Medium13

Low0

Info0

Code attribute

Status

Security Category

Creation Date

Language

□

Define a constant instead of duplicating this literal "OWASP Top 10:2025" 3 times.

Adaptability

Maintainability

High

Open

Not assigned

L53

6min effort

6 days ago

□

Refactor this function to reduce its Cognitive Complexity from 22 to the 15 allowed.

Adaptability

Maintainability

High

Open

Not assigned

L199

12min effort

6 days ago

evals/pentest.py

□

Define a constant instead of duplicating this literal "ask:read" 3 times.

Adaptability

Maintainability

High

Open

Not assigned

L67

6min effort

6 days ago

□

Define a constant instead of duplicating this literal "/auth/token" 6 times.

Adaptability

Maintainability

High

Open

Not assigned

L100

12min effort

6 days ago

□

Define a constant instead of duplicating this literal "/admin/ingest" 5 times.

Adaptability

Maintainability

High

Open

Not assigned

L195

10min effort

6 days ago

6 / 12

The screenshot displays the SonarQube web interface. On the left, a sidebar lists various filters: Blocker (5), High (17), Medium (13), Low (0), and Info (0). Below these are expandable sections for 'Code attribute', 'Status', 'Security Category', 'Creation Date', and 'Language'. The main area shows two specific issues. The first issue, titled 'Refactor this function to reduce its Cognitive Complexity from 33 to the 15 allowed.', is located in 'evals/preguntas_trampa.py'. It has a 'Maintainability' quality gate set to 'High' and is marked as 'Open' and 'Not assigned'. The second issue, titled 'Refactor this function to reduce its Cognitive Complexity from 21 to the 15 allowed.', is in 'evals/roleplay_estabilidad.py'. It also has a 'Maintainability' quality gate set to 'High' and is marked as 'Open' and 'Not assigned'. Both issues include a 'brain-overload' indicator and a '+'. At the bottom, it shows '35 of 35 shown' and a footer with copyright information and links to Terms, Pricing, Privacy, etc.

5.2. Gitleaks (Detección de Secretos)

Comando utilizado:

```
gitleaks detect --source . -r report.json -f json
```

Captura de pantalla:

The screenshot shows a terminal window with the command `gitleaks detect --source . -r report.json -f json` executed. The output indicates that 47 commits were scanned, approximately 518,068 bytes (518.07 KB) were scanned in 98.1ms, and 4 leaks were found. The terminal also shows a file tree view on the left with 'gitleaks' highlighted.

5.3. Bandit (Análisis Estático para Python)

Comando utilizado:

```
bandit -r app
```

Captura de pantalla:

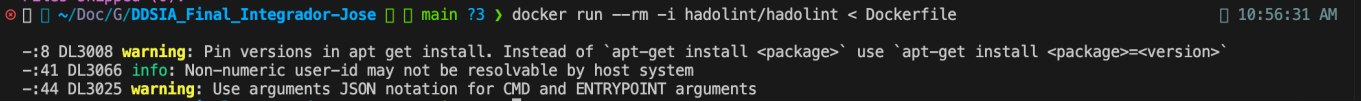
The screenshot shows a terminal window with the command `bandit -r app` executed. The output displays various informational messages, including the profile used, the Python version (3.14.7), and the start time. The 'Test results' section shows 'No issues identified.' The 'Code scanned' section shows 'Total lines of code: 1921' and 'Total lines skipped (#nosec): 0'. The 'Run metrics' section shows 'Total issues (by severity): Undefined: 0, Low: 0, Medium: 0, High: 0' and 'Total issues (by confidence): Undefined: 0, Low: 0, Medium: 0, High: 0'. Finally, it shows 'Files skipped (0):'.

5.4. Hadolint (Linting de Dockerfiles)

Comando utilizado:

```
docker run --rm -i hadolint/hadolint < Dockerfile
```

Captura de pantalla:



5.5. Trivy (Escaneo de Contenedores y Dependencias)

Comando utilizado:

```
trivy image --format template --template
"@/opt/homebrew/share/trivy/templates/html.tpl" --output report.html owasp-
rag-assistant:1.0.0
```

Captura de pantalla:

owasp-rag-assistant:1.0.0 (debian 12.15) - Trivy Report - 2026-08-30 12:43:45.018633 -0400 EDT
m=+6.986190709

debian					
Package	Vulnerability ID	Severity	Installed Version	Fixed Version	Links
apt	CVE-2011-3374	LOW	2.6.1		https://access.redhat.com/security/cve/cve-2011-3374 https://bugs.debian.org/cgi-bin/bugreport.cgi?bug=642480 https://people.canonical.com/~ubuntu-security/cve/2011/CVE-2011-3374.html Toggle more links
bash	TEMP-0841856-B18BAF	LOW	5.2.15-2+b13		
bsdutils	CVE-2026-53613	HIGH	1:2.38.1-5+deb12u3		https://access.redhat.com/security/cve/CVE-2026-53613 https://github.com/util-linux/util-linux/security/advisories/GHSA-8gj5-72r3-428g https://nvd.nist.gov/vuln/detail/CVE-2026-53613 Toggle more links
bsdutils	CVE-2026-53615	HIGH	1:2.38.1-5+deb12u3		
bsdutils	CVE-2026-13595	MEDIUM	1:2.38.1-5+deb12u3		https://access.redhat.com/errata/RHSA-2026:26573 https://access.redhat.com/security/cve/CVE-2026-13595 https://bugzilla.redhat.com/show_bug.cgi?id=2494101 Toggle more links
bsdutils	CVE-2026-27456	MEDIUM	1:2.38.1-5+deb12u3		http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2026-27456 https://access.redhat.com/security/cve/CVE-2026-27456 https://github.com/bottlerocket-os/bottlerocket-core-kit/blob/develop/advisories/14.5.0/BRSA-jgcxwxt3xsd.toml Toggle more links
bsdutils	CVE-2026-3184	MEDIUM	1:2.38.1-5+deb12u3		https://access.redhat.com/errata/RHSA-2026:7180 https://access.redhat.com/security/cve/CVE-2026-3184 https://bugzilla.redhat.com/show_bug.cgi?id=2442570 Toggle more links
bsdutils	CVE-2022-0563	LOW	1:2.38.1-5+deb12u3		http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-0563 https://access.redhat.com/security/cve/CVE-2022-0563 https://blog.trailofbits.com/2023/02/16/suid-logic-bug-linux-readline/ Toggle more links
bsdutils	CVE-2025-14104	LOW	1:2.38.1-5+deb12u3		https://access.redhat.com/errata/RHSA-2026:1696 https://access.redhat.com/errata/RHSA-2026:1852 https://access.redhat.com/errata/RHSA-2026:1913 Toggle more links
coreutils	CVE-2016-2781	LOW	9.1-1		http://www.openwall.com/lists/oss-security/2016/02/28/2 http://www.openwall.com/lists/oss-security/2016/02/28/3 https://access.redhat.com/security/cve/CVE-2016-2781 Toggle more links

					Toggle more links
libsmartcols1	CVE-2022-0563	LOW	2.38.1-5+deb12u3		http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-0563 https://access.redhat.com/security/cve/CVE-2022-0563 https://blog.trailofbits.com/2023/02/16/suid-logic-bug-linux-readline/ Toggle more links
libsmartcols1	CVE-2025-14104	LOW	2.38.1-5+deb12u3		https://access.redhat.com/errata/RHSA-2026-1696 https://access.redhat.com/errata/RHSA-2026-1852 https://access.redhat.com/errata/RHSA-2026-1913 Toggle more links
libsqlite3-0	CVE-2025-7458	CRITICAL	3.40.1-2+deb12u2		https://access.redhat.com/security/cve/CVE-2025-7458 https://nvd.nist.gov/vuln/detail/CVE-2025-7458 https://sqlite.org/forum/forumpost/16ce2bb7a639e29b Toggle more links
libsqlite3-0	CVE-2026-11822	HIGH	3.40.1-2+deb12u2		https://access.redhat.com/errata/RHSA-2026-58936 https://access.redhat.com/security/cve/CVE-2026-11822 https://bugzilla.redhat.com/show_bug.cgi?id=2487258 Toggle more links
libsqlite3-0	CVE-2026-11824	HIGH	3.40.1-2+deb12u2		https://access.redhat.com/errata/RHSA-2026-58936 https://access.redhat.com/security/cve/CVE-2026-11824 https://bugzilla.redhat.com/show_bug.cgi?id=2487258 Toggle more links
libsqlite3-0	CVE-2025-7709	MEDIUM	3.40.1-2+deb12u2		http://www.openwall.com/lists/oss-security/2025/09/06/2 http://www.openwall.com/lists/oss-security/2025/11/18/10 https://github.com/google/security-research/security/advisories/GHSA-v2c8-vgqp-hv3g Toggle more links
libsqlite3-0	CVE-2026-50812	MEDIUM	3.40.1-2+deb12u2		https://access.redhat.com/security/cve/CVE-2026-50812 https://gist.github.com/junius-sec/bb556f33957c5226dede314db0e9e91 https://github.com/sqlite/sqlite/commit/b869ed6b067d623cb1383549f2a18aa35508385d Toggle more links
libsqlite3-0	CVE-2026-50813	MEDIUM	3.40.1-2+deb12u2		https://access.redhat.com/security/cve/CVE-2026-50813 https://gist.github.com/junius-sec/f8acb66baf80134c8e1a1c8c7c9f4f4 https://github.com/sqlite/sqlite/commit/c597ed79d1bd03f57198d10d1f431adda293cf2e Toggle more links
libsqlite3-0	CVE-2021-45346	LOW	3.40.1-2+deb12u2		https://access.redhat.com/security/cve/CVE-2021-45346 https://github.com/guylinaluxedo/sqlite3_record_leaking https://nvd.nist.gov/vuln/detail/CVE-2021-45346 Toggle more links
libsqlite3-0	CVE-2025-29088	LOW	3.40.1-2+deb12u2		https://access.redhat.com/security/cve/CVE-2025-29088 https://gist.github.com/ywang0613/d3883fb9f6ba8a78086356779ce88248 https://github.com/sqlite/sqlite/commit/56d2fd008b108109f489339f5fd55212bb50afd4 Toggle more links
libsqlite3-0	CVE-2025-70873	LOW	3.40.1-2+deb12u2		https://access.redhat.com/security/cve/CVE-2025-70873 https://gist.github.com/cnwangjihf/f496393f30f5ecec5b18c8f5ab072054 https://nvd.nist.gov/vuln/detail/CVE-2025-70873 Toggle more links

Resumen Ejecutivo de Vulnerabilidades - Trivy Scan

Este reporte resume los hallazgos principales del escaneo de seguridad de contenedores para la imagen `owasp-rag-assistant:1.0.0` (basada en Debian 12.15).

Se ha priorizado la enumeración de las vulnerabilidades **CRITICAL** y **HIGH** debido a su impacto directo en la infraestructura y las operaciones.

Vulnerabilidades Prioritarias (CRITICAL & HIGH)

Nivel de Riesgo	ID de Vulnerabilidad (CVE)	Paquete Afectado	Versión Actual	Versión Corregida (Parche)
CRITICAL	CVE-2025-7458	libsqlite3-0	3.40.1-2+deb12u2	-
HIGH	CVE-2026-53613 / 53615	bsdutils, libblkid1 (y dependencias)*	1:2.38.1-5+deb12u3	-
HIGH	CVE-2026-41992	gzip	1.12-1	-
HIGH	CVE-2026-54369	libacl1	2.3.1-3	-
HIGH	CVE-2026-11822 / 11824	libsqlite3-0	3.40.1-2+deb12u2	-
HIGH	CVE-2025-69720	libncursesw6, libtinfo6**	6.4-4	-

* Afecta también a `libmount1` y `libuuid1`. ** Afecta a bibliotecas de manejo de terminales.

Análisis de Nivel Medio y Bajo (MEDIUM & LOW)

Las imágenes contienen un volumen significativo de hallazgos de menor criticidad (MEDIUM, LOW, UNKNOWN). Las superficies más afectadas incluyen:

- **MEDIUM:** 38 vulnerabilidades detectadas en componentes esenciales como `libc-bin`, `libc6` (CVE-2026-5435, CVE-2026-5450, CVE-2026-6238), utilidades de `bsdutils`, `gpgv`, `libattr1` y `libbz2-1.0`.
- **LOW:** 56 vulnerabilidades en herramientas del sistema operativo base como `apt`, `coreutils`, `bash`, `diffutils` y `libssl3`.

Recomendaciones de Remediación

1. **Actualizar Paquetes Críticos:** Es imperativo actualizar `libsqlite3-0` para mitigar la vulnerabilidad crítica (CVE-2025-7458) y las de nivel alto (CVE-2026-11822, CVE-2026-11824).
2. **Actualizar Utilidades del Sistema (Util-linux y gzip):** Aplicar parches a las librerías base de manipulación de almacenamiento y compresión (`bsdutils`, `libblkid1`, `gzip`) para cerrar las brechas de severidad alta.
3. **Reconstrucción del Contenedor:** Ejecutar un `apt-get update && apt-get upgrade` en el Dockerfile para incorporar los parches oficiales de seguridad más recientes disponibles para Debian 12.

5.6. OWASP ZAP (Análisis Dinámico - DAST)

Comando utilizado:

```
docker run --rm -v $(pwd):/zap/wrk/:rw --network="host" -t zapproxy/zap-stable zap-full-scan.py -t http://localhost:8000 -r owasp-report.html
```

Captura de pantalla:



Sites: https://localhost:8000 http://localhost:8000

Generated on Sun, 30 Aug 2026 16:51:10

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	3
Low	5
Informational	5
False Positives:	0

Insights

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP warnings logged - see the zap.log file for details	14
Low	Exceeded High	http://localhost:8000	Percentage of responses with status code 4xx	94 %
info	Informational	http://localhost:8000	Percentage of responses with status code 2xx	5 %
info	Informational	http://localhost:8000	Percentage of endpoints with content type application/json	8 %
info	Informational	http://localhost:8000	Percentage of endpoints with content type application/problem+json	16 %
info	Informational	http://localhost:8000	Percentage of endpoints with content type image/svg+xml	8 %
info	Informational	http://localhost:8000	Percentage of endpoints with content type text/css	8 %
info	Informational	http://localhost:8000	Percentage of endpoints with content type text/html	41 %
info	Informational	http://localhost:8000	Percentage of endpoints with content type text/javascript	16 %
info	Informational	http://localhost:8000	Percentage of endpoints with method GET	100 %
info	Informational	http://localhost:8000	Count of total endpoints	12
info	Informational	https://cdn.jsdelivr.net	Percentage of responses with status code 2xx	100 %
info	Informational	https://cdn.jsdelivr.net	Percentage of slow responses	100 %
info	Informational	https://fastapi.tiangolo.com	Percentage of responses with status code 2xx	100 %
info	Informational	https://fastapi.tiangolo.com	Percentage of slow responses	100 %
info	Informational	https://localhost:8000	Percentage of endpoints with method GET	100 %
info	Informational	https://localhost:8000	Count of total endpoints	1

Summary of Sequences

For each step: result (Pass/Fail) - risk (of highest alert(s) for the step, if any).

Alerts

Name	Risk Level	Number of Instances
Content Security Policy (CSP) Header Not Set	Medium	1
HTTP Only Site	Medium	1
Sub Resource Integrity Attribute Missing	Medium	2
Cross-Domain JavaScript Source File Inclusion	Low	1
Cross-Origin-Embedder-Policy Header Missing or Invalid	Low	3
Cross-Origin-Opener-Policy Header Missing or Invalid	Low	3
Cross-Origin-Resource-Policy Header Missing or Invalid	Low	Systemic
Permissions Policy Header Not Set	Low	Systemic
Information Disclosure - Suspicious Comments	Informational	1
Modern Web Application	Informational	1
Non-Storable Content	Informational	Systemic
User Agent Fuzzer	Informational	Systemic
User Controllable HTML Element Attribute (Potential XSS)	Informational	2

Alert Detail

Medium	Content Security Policy (CSP) Header Not Set
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page – covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://localhost:8000/docs
Node Name	http://localhost:8000/docs
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
Instances	1
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/?feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038
Medium	HTTP Only Site
Description	The site is only served under HTTP and not HTTPS.
URL	http://localhost:8000/?fuente=web&pregunta
Node Name	https://localhost:8000/
Method	GET
Parameter	
Attack	
Evidence	
Other Info	Failed to connect. ZAP attempted to connect via: https://localhost:8000/
Instances	1
Solution	Configure your web or application server to use SSL (https).
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Protection_Cheat_Sheet.html https://letsencrypt.org/
CWE Id	311
WASC Id	4
WASC Id	4
Plugin Id	10106
Medium	Sub Resource Integrity Attribute Missing
Description	The integrity attribute is missing on a script or link tag served by an external server. The integrity tag prevents an attacker who have gained access to this server from injecting a malicious content.
URL	http://localhost:8000/docs
Node Name	http://localhost:8000/docs
Method	GET
Parameter	
Attack	
Evidence	<link type="text/css" rel="stylesheet" href="https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui.css">
Other Info	
URL	http://localhost:8000/docs
Node Name	http://localhost:8000/docs
Method	GET
Parameter	
Attack	
Evidence	<script src="https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js"></script>
Other Info	
Instances	2
Solution	Provide a valid integrity attribute to the tag.
Reference	https://developer.mozilla.org/en-US/docs/Web/Security/Defenses/Subresource_Integrity
CWE Id	345
WASC Id	15
Plugin Id	90003
Low	Cross-Domain JavaScript Source File Inclusion
Description	The page includes one or more script files from a third-party domain.
URL	http://localhost:8000/docs
Node Name	http://localhost:8000/docs
Method	GET
Parameter	https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js
Attack	
Evidence	<script src="https://cdn.jsdelivr.net/npm/swagger-ui-dist@5/swagger-ui-bundle.js"></script>
Other Info	
Instances	1
Solution	Ensure JavaScript source files are loaded from only trusted sources, and the sources can't be controlled by end users of the application.
Reference	
CWE Id	829
WASC Id	15